

1. OAuth Logic: Prefix Collision (Unico)

I. ARCHITECTURAL ROOT CAUSE

Loose prefix validation vs. Closed-set validation.

II. ADVANCED EXPLOITATION POC

```
curl -X POST -d '{"redirectURL": "..."}'
```

III. PERIMETER EVASION STRATEGY

Host Mocking via sub-TLD structure.

IV. STRATEGIC REMEDIATION

Strict URI registration policy.

V. CASE STUDY ANALYSIS

Unico Authorization Code Theft.

2. Telemetry: InfluxDB Sink Poisoning

I. ARCHITECTURAL ROOT CAUSE

Internal trust propagation to public Envoy proxies.

II. ADVANCED EXPLOITATION POC

```
curl -d 'system_health,status=DOWN'
```

III. PERIMETER EVASION STRATEGY

Protocol camouflage in telemetry streams.

IV. STRATEGIC REMEDIATION

VPC Network segmentation & mTLS.

V. CASE STUDY ANALYSIS

Banco Plata operational chaos.

3. Perimeter: Origin IP Exposure (CoinMate)

I. ARCHITECTURAL ROOT CAUSE

Inbound security group misconfiguration (0.0.0.0/0).

II. ADVANCED EXPLOITATION POC

```
curl -k -H 'Host: start.coinmate.io' https://IP
```

III. PERIMETER EVASION STRATEGY

Direct-to-IP WAF negation.

IV. STRATEGIC REMEDIATION

Cloud-level IP whitelisting.

V. CASE STUDY ANALYSIS

Direct DB/SSH exposure.

4. Secret Leaks: Firebase Key Chaining

I. ARCHITECTURAL ROOT CAUSE

Client-side bundling of static environment secrets.

II. ADVANCED EXPLOITATION POC

```
curl -H 'X-Firebase-API-Key: ...'
```

III. PERIMETER EVASION STRATEGY

Authenticated status spoofing on Origin.

IV. STRATEGIC REMEDIATION

Secrets management via Vault.

V. CASE STUDY ANALYSIS

Firebase-to-Origin bypass chain.

5. JS Recon: The Secret Mining Strategy

I. ARCHITECTURAL ROOT CAUSE

Bundling sensitive API/Internal routes in SPAs.

II. ADVANCED EXPLOITATION POC

```
grep -rE 'ADMIN_ROUTE|STAGING_IP'
```

III. PERIMETER EVASION STRATEGY

Bypassing documentation-only security.

IV. STRATEGIC REMEDIATION

Code minification & dynamic config.

V. CASE STUDY ANALYSIS

Discovering unauthenticated beta APIs.

6. Logic Flaws: Race Condition Concurrency

I. ARCHITECTURAL ROOT CAUSE

Multi-threaded state manipulation failures.

II. ADVANCED EXPLOITATION POC

Turbo Intruder 'gate' synchronization.
--

III. PERIMETER EVASION STRATEGY

HTTP/2 multi-stream request batches.

IV. STRATEGIC REMEDIATION

Atomic state updates & locking.

V. CASE STUDY ANALYSIS

Financial transaction duplication.

7. DNS Poisoning: Subdomain Shadowing

I. ARCHITECTURAL ROOT CAUSE

Improper CNAME/Record management on nameservers.

II. ADVANCED EXPLOITATION POC

```
dig @ns idpay.target.com.evil.com
```

III. PERIMETER EVASION STRATEGY

Parallel trust structure creation.

IV. STRATEGIC REMEDIATION

Strict zone file monitoring.

V. CASE STUDY ANALYSIS

Bypassing redirection security.

8. Exploit Chaining: High Impact ROI

I. ARCHITECTURAL ROOT CAUSE

Linking 'Low' CORS leaks to 'Critical' CSRF.

II. ADVANCED EXPLOITATION POC

Origin: * -> read token -> Action Trigger.
--

III. PERIMETER EVASION STRATEGY

Normalization difference bypassing WAF.

IV. STRATEGIC REMEDIATION

Cross-domain read-access restrictions.

V. CASE STUDY ANALYSIS

Account Takeover via logic chaining.

9. HTTP/2 Smuggling & Tunneling

I. ARCHITECTURAL ROOT CAUSE

De-synchronization between WAF and backend parser.

II. ADVANCED EXPLOITATION POC

HTTP/2 :authority header manipulation.
--

III. PERIMETER EVASION STRATEGY

Header-folding / Large-buffer evasion.

IV. STRATEGIC REMEDIATION

Forced HTTP/1.1 backend downgrades.

V. CASE STUDY ANALYSIS

Request Smuggling for Admin access.

10. Sovereign Reporting & Remediation

I. ARCHITECTURAL ROOT CAUSE

Focusing on business risk (Revenue/Stability).

II. ADVANCED EXPLOITATION POC

Formula: Vuln + Chain + Biz Impact = P1.
--

III. PERIMETER EVASION STRATEGY

WAF signature updates vs Infrastructure fix.

IV. STRATEGIC REMEDIATION

C-Level Risk management alignment.

V. CASE STUDY ANALYSIS

Designing 'Fixes' that kill bug classes.

FINAL ASSESSMENT: ELITE MASTERY TEST

This quiz tests your integrated knowledge from Courses 1, 2, 3, and 4. You must understand root causes, chaining logic, and perimeter bypasses to answer.

Q1: In the Unico IDtech case, why did 'idpay.unico.io.ayman.com' bypass the redirect validation?

- ☐ The WAF was turned off
- ☐ The validator used 'startsWith' prefix-matching instead of absolute matching
- ☐ IDpay is a reserve word in OAuth RFC
- ☐ The attacker compromised the DNS of unico.io

Q2: What is the most effective 'C-Level' fix for an exposed Origin IP (CoinMate scenario)?

- ☐ Install a stronger WAF
- ☐ Obfuscate the IP in DNS records
- ☐ Configure the Cloud Firewall to only allow Inbound traffic from Cloudflare IPs
- ☐ Change the SSH and DB port numbers

Q3: How does 'Race Condition' exploitation relate to 'Concurrency' (Course 4)?

- ☐ It exploits the speed of the internet connection
- ☐ It exploits failures in atomicity when multiple requests hit the same logic simultaneously
- ☐ It only works on slow websites
- ☐ It is a type of DDoS attack

Q4: Which chain turning a 'Low' bug into 'Critical' was discussed in Course 3/4?

- ☐ Missing Alt-text to SQLi
- ☐ Broken Image Link to SSRF
- ☐ CORS Misconfiguration (Origin: *) to CSRF/Account Takeover
- ☐ Dead Link to Social Engineering

Q5: In the context of WAF Evasion, what is 'Protocol Camouflage'?

- ☐ Encoding text as binary telemetry (Line Protocol) to bypass string inspection
- ☐ Using HTTPS instead of HTTP
- ☐ Hiding the IP via a VPN
- ☐ Masking the User-Agent as a Search Engine